Information Access Control Standard

Standard ID: GRC-AC-2026
Version: 1.0
Owner: Information Security
Effective Date: 2026-01-01
Classification: Internal

1. Purpose and Scope

This standard defines the mandatory controls governing access to production systems and confidential data. It applies to all employees, contractors, and third parties who are granted access to organizational information systems.

2. Definitions

An "account" is any credential permitting authentication to a system. A "privileged account" is any account holding administrative rights. "Access review" means a documented confirmation that a person’s access remains appropriate for their role.

3. Account Provisioning

3.1 Access must be approved by the data owner before the account is created.

3.2 Access must be granted on the principle of least privilege. A person must receive only the permissions required to perform their role.

3.3 Shared accounts must not be used for privileged access. Every privileged action must be attributable to one named individual.

4. Authentication

4.1 Multi-factor authentication must be enforced for all remote access to production systems.

4.2 Passwords must be at least twelve characters in length.

4.3 Passwords must not be transmitted or stored in plain text.

5. Access Review and Revocation

5.1 Access rights must be reviewed at least quarterly by the data owner.

5.2 Access must be revoked within twenty-four hours of a person leaving the organization.

5.3 The results of each access review must be recorded, including the reviewer identity and the date of review.

6. Privileged Access

6.1 Privileged access must be time-limited and granted only for the duration of the approved task.

6.2 All privileged sessions must be logged, and session logs must be retained for twelve months.

7. Guidance

Teams should consider adopting hardware security keys where practical. This is a recommendation and is not a mandatory control.